

2018-09-27 TRAFFIC ANALYSIS EXERCISE - ANSWERS

<https://www.malware-traffic-analysis.net/2018/09/27/index.html>

You have:

- a pcap with a Windows host getting infected.
- two emails.

Your task:

- Figure out which one of the two emails kicked off the infection traffic in the pcap.

ANSWER:

The first email (1 of 2) with the subject line: Conversa do WhatsApp no (221206).

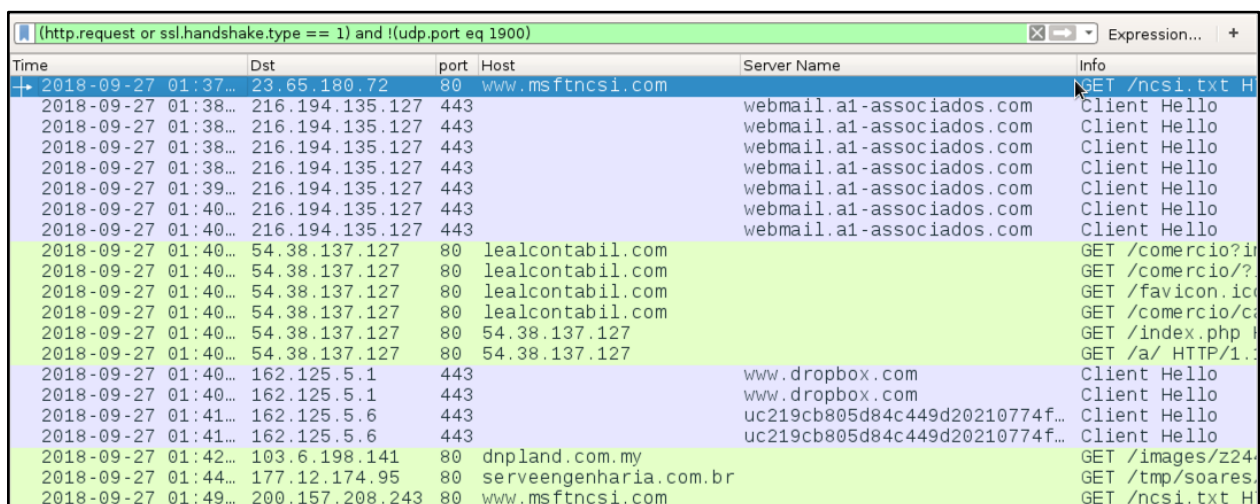
DETAILS:

As always before doing these exercises, I recommend you have customize your column display in Wireshark. I've written a guide here:

- <https://researchcenter.paloaltonetworks.com/2018/08/unit42-customizing-wireshark-changing-column-display/>

My standard filter to quickly review traffic is: **(http.request or ssl.handshake.type == 1) and !(udp.port eq 1900)**

UDP port 1900 tends to have SSDP-based HTTP traffic associated with Plug and Play and it always gets in the way of reviewing malicious traffic. Use that filter to open this month's exercise pcap.



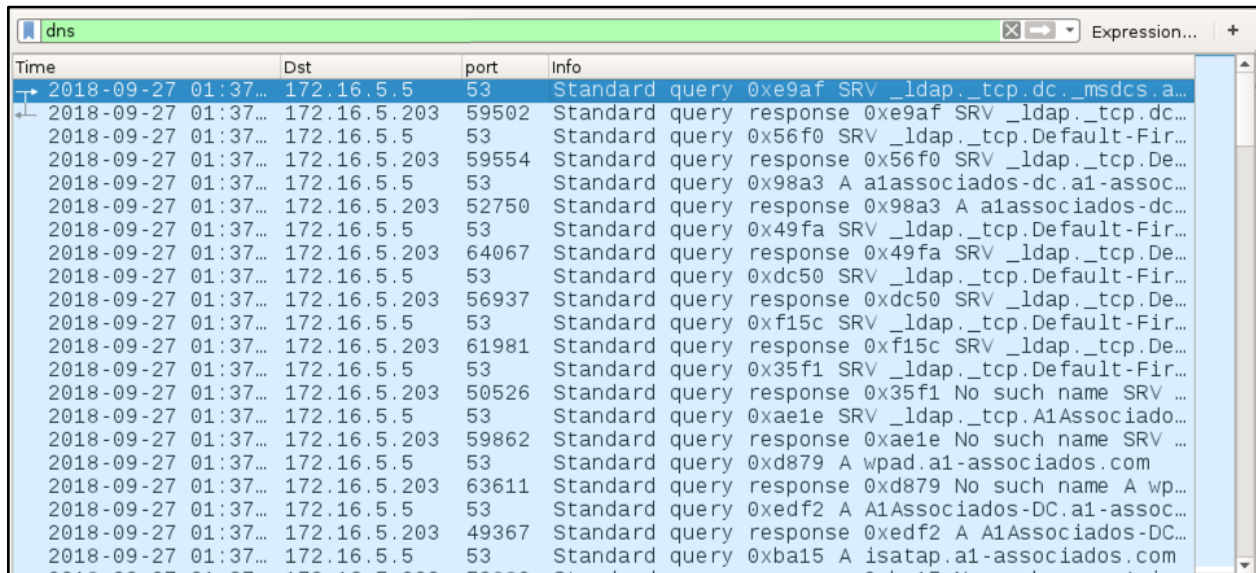
Time	Dst	port	Host	Server Name	Info
2018-09-27 01:37...	23.65.180.72	80	www.msftncsi.com		GET /ncsi.txt H
2018-09-27 01:38...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:38...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:38...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:38...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:39...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:40...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:40...	216.194.135.127	443		webmail.a1-associados.com	Client Hello
2018-09-27 01:40...	54.38.137.127	80	lealcontabil.com		GET /comercio?i
2018-09-27 01:40...	54.38.137.127	80	lealcontabil.com		GET /comercio/?
2018-09-27 01:40...	54.38.137.127	80	lealcontabil.com		GET /favicon.ic
2018-09-27 01:40...	54.38.137.127	80	lealcontabil.com		GET /comercio/c
2018-09-27 01:40...	54.38.137.127	80	54.38.137.127		GET /index.php
2018-09-27 01:40...	54.38.137.127	80	54.38.137.127		GET /a/ HTTP/1.
2018-09-27 01:40...	162.125.5.1	443		www.dropbox.com	Client Hello
2018-09-27 01:40...	162.125.5.1	443		www.dropbox.com	Client Hello
2018-09-27 01:41...	162.125.5.6	443		uc219cb805d84c449d20210774f...	Client Hello
2018-09-27 01:41...	162.125.5.6	443		uc219cb805d84c449d20210774f...	Client Hello
2018-09-27 01:42...	103.6.198.141	80	dnpland.com.my		GET /images/z24
2018-09-27 01:44...	177.12.174.95	80	serveengenharia.com.br		GET /tmp/soares.
2018-09-27 01:49...	200.157.208.243	80	www.msftncsi.com		GET /ncsi.txt H

Shown above: Traffic from this month's exercise pcap filtered in Wireshark.

2018-09-27 TRAFFIC ANALYSIS EXERCISE - ANSWERS

The first line to **www.msftncsi.com** represents traffic that occurs shortly after a Windows computer boots and starts up. It's normal traffic. Notice there's another HTTP request to **www.msftncsi.com** later in the pcap, which in this case indicates the Windows host rebooted.

The first important traffic we see is HTTPS/SSL traffic to **webmail.a1-associados.com**. If you check dns traffic in the pcap, you'll find several DNS queries for names ending in **a1-associados.com**. Stuff like **A1Associados-DC.a1-associados.com** and **wpad.a1-associados.com**. The domain **a1-associados.com** is used in the internal network, and it's the domain for this LAN segment of IP address space covering 172.16.5.0/24.



Time	Dst	port	Info
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xe9af SRV _ldap._tcp.dc._msdcs.a...
2018-09-27 01:37...	172.16.5.203	59502	Standard query response 0xe9af SRV _ldap._tcp.dc...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0x56f0 SRV _ldap._tcp.Default-Fir...
2018-09-27 01:37...	172.16.5.203	59554	Standard query response 0x56f0 SRV _ldap._tcp.De...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0x98a3 A a1associados-dc.a1-assoc...
2018-09-27 01:37...	172.16.5.203	52750	Standard query response 0x98a3 A a1associados-dc...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0x49fa SRV _ldap._tcp.Default-Fir...
2018-09-27 01:37...	172.16.5.203	64067	Standard query response 0x49fa SRV _ldap._tcp.De...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xdc50 SRV _ldap._tcp.Default-Fir...
2018-09-27 01:37...	172.16.5.203	56937	Standard query response 0xdc50 SRV _ldap._tcp.De...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xf15c SRV _ldap._tcp.Default-Fir...
2018-09-27 01:37...	172.16.5.203	61981	Standard query response 0xf15c SRV _ldap._tcp.De...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0x35f1 SRV _ldap._tcp.Default-Fir...
2018-09-27 01:37...	172.16.5.203	50526	Standard query response 0x35f1 No such name SRV ...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xae1e SRV _ldap._tcp.A1Associado...
2018-09-27 01:37...	172.16.5.203	59862	Standard query response 0xae1e No such name SRV ...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xd879 A wpad.a1-associados.com
2018-09-27 01:37...	172.16.5.203	63611	Standard query response 0xd879 No such name A wp...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xedf2 A A1Associados-DC.a1-assoc...
2018-09-27 01:37...	172.16.5.203	49367	Standard query response 0xedf2 A A1Associados-DC...
2018-09-27 01:37...	172.16.5.5	53	Standard query 0xba15 A isatap.a1-associados.com

Shown above: Some of the DNS traffic in the pcap.

This indicates the victim went to **webmail.a1-associados.com** to review his or her email using a web browser. The two emails included with this exercise represent two emails the victim received. They are in the EML format, so we can use an email client like Thunderbird to quickly review them.

Reviewing both emails in Thunderbird shows neither one has attachments, but both have links. In the first email, the link is to:

- http://lealcontabil.com/comercio?imagens/img/tmp/a?onlinepor-email?e=whatsapp_Backup_REG

In the second email, the link is to:

- http://consultafacilserasaexperian.com/clientes?serasaconsumidor?gclid=EAlaIqobChMImqi3i4633QIVT4GRCh0ZBgZMEAAYASAAEgKpR_D_BwE

2018-09-27 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Conversa do WhatsApp no (221206) - Mozilla Thunderbird

File Edit View Go Message Tools Help

From: WhatsApp-WEB <nwindows@communication.microsoft.com> ☆

Subject: **Conversa do WhatsApp no (221206)**

To: thiago.almeida@a1-associados.com ☆

9/24/2018 12:52 PM

Affs. Imbecil !
acho que eu nunca ia ficar sabendo dessa safadeza ?
pois você se engano! Já sei de tudo !!

me mandar foto da sua conversa com os outros ao meu respeito!

toma ai registro da sua conversa



http://lealcontabil.com/comercio?imagens/img/tmp/a?onlinepor-email?e=whatsapp_Backup_REG

[Whatsapp_Backup_REG\(656386387\).zip](#)

E fica já Sabendo que isto nunca que vai ficar por isto mesmo, ok?
Adeus

EMAIL 1 OF 2

Anotacao de Extrato De Debitos para seu CPF/CNPJ. No (778071) - Mozilla Thunderbird

File Edit View Go Message Tools Help

From: Comunicado | Serasa Experian <atendimento@serasaexperian.com.br> ☆

Subject: **Anotacao de Extrato De Debitos para seu CPF/CNPJ. No (778071)**

To: thiago.almeida@a1-associados.com ☆

9/26/2018 4:19 PM



http://consultafacilserasaexperian.com/clientes?serasaconsumidor?gclid=EAlaIqobChMIImqi3i4633QIVT4GRCh0ZBgZMEAAAYASAAEgKpR_D_BwE

COMUNICADO IMPORTANTE Nº 20180354927618

São Paulo, quarta-feira 26 de setembro de 2018

Prezado(a) Senhor(a),

Para a preservação da qualidade e da segurança dos serviços prestado a comunidade e cumprimento do disposto no art.43, parágrafo segundo, da lei nº 8.078 de 11 de setembro de 1990, informamos que recebemos da instituição credora, pedido de inclusão em nossos registros da(s) anotação(ões) abaixo denominada(s), para o CPF/CNPJ correspondente a E-mail .

Valor da anotação - Data da ocorrência - Natureza

[Consultar Extrato de Débitos Detalhados](#)

EMAIL 2 OF 2

2018-09-27 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Review the traffic, you'll find an HTTP request to **lealcontabil.com** that matches the URL for **http://lealcontabil.com/comercio?imagens/img/tmp/a?onlinepor-email?e=whatsapp_Beckup_REG** from the first email.

You can also find more information from the pcap. The **lealcontabil.com** URL led to **<http://54.38.137.127/index.php>**, which redirected to a Dropbox URL at **https://www.dropbox.com/s/0yggmgtymt2r0av/DOC1_CONTRATO_YBFTOP2078686788.zip?dl=1**

That Dropbox URL was no longer active when I checked, but it was still live during the pcap's timeframe. Unfortunately, there's not much more we can learn from the pcap.

Traffic to **dnpland.com.my/images/z2448800.zip** returned encoded data that was not a zip archive (probably decrypted after it went to the victim's host). The next URL to **serveengenharia.com.br/tmp/soares/cont1/** redirected traffic to Google's home page.

None of this triggered any meaningful alerts when I reviewed the traffic using Snort with the Talos ruleset or Suricata with the ETPRO ruleset.

You can still review the pcap and find other information, like the user account and host name of the infected Windows host.